



Risk Assessment of a targeted Cyberattack on a critical Cyber-Physical System: a Bayesian Network approach using AgenaRisk

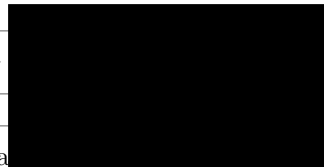
Methods and Data Analytics for Risk Assessment — Group Project

Group Number: 1

Academic Year 2026

Authors:

Giacomo Nigro —
Luigi Tiberio —
Stefano Moreschi —
Mattia Silvestri —
Aleksandra Kovaleva —



Contents

1	Research question	1
2	Introduction	1
2.1	Data and calibration	1
2.2	Modeling strategy	1
3	The Bayesian Network model	2
3.1	Nodes and types	2
3.2	Structure and links	2
3.3	Assumptions and considerations about CPTs	3
4	Weaknesses and limits of the model	3
5	Scenario analysis and quantitative results	4
5.1	Case 1 - Strong Detect and Respond against skilled attacker (2022 attack)	4
5.2	Case 2 - Weak Detect and Respond against skilled attacker	4
5.3	Case 3 - Medium Detect and Respond against skilled attacker (2016 attack)	4
5.4	Case 4 - Recovery comparison after severe disruption	4
6	Conclusion	5
7	Appendix	6
7.1	Appendix A. Important figures and AgenaRisk screenshots	6
7.2	Appendix B. Node definitions and source logic	11
7.3	Appendix C. Priors and conditional probability tables	13
7.4	Appendix D. Scenario evidence and full output tables	16

1 Research question

Given a targeted cyberattack against a critical OT-enabled power-system operator, how does the posterior probability distribution of end-user service disruption change as attacker success, Detect, Respond and Recover capabilities vary?

2 Introduction

Industroyer2 was a powerful cyberattack deployed against the Ukrainian power grid in 2022. This report designs and analyzes a Bayesian network for an Industroyer2-like cyberattack against an electrical substation or a comparable OT-enabled cyber-physical system. This is relevant because power grids are critical infrastructures: even a limited technical disruption can create serious consequences for end users if detection, response and recovery are weak. The target outcome is Service_Impact, defined as the final user-facing consequence for electricity users. A separate node, Power_Disruption, represents the immediate operational disruption at substation, control-room or power-system level. Keeping these nodes distinct is important: a technical disruption does not automatically translate into the same level of final service impact if response and recovery capabilities absorb part of the shock. Bayesian networks are useful for representing this type of cyberattack because they can connect the main elements of the attacker, the defender and the environment, together with their probabilistic relationships. The model is not presented as a forecast of a real substation blackout. It is a comparative probabilistic model. Its purpose is to translate the qualitative logic of our previous analyses shown in the Appendix, (namely FTA, ETA and FMEA), into posterior distributions that can be compared across evidence settings. The resulting numbers should therefore be read mainly as conditional outputs of the stated model calibration, not as absolute frequencies. Moreover, Bayesian networks are suitable for this project because the available evidence is incomplete, mixed and partly qualitative; we can try to translate all this information in quantitative probabilistic output. The technical sources support the structure of the attack path, for example the need for OT access, OT knowledge and valid IEC-104 command execution. However, they do not provide enough observations to estimate all probabilities statistically, so BNs may be used as a simple yet precise schema for our scope.

2.1 Data and calibration

The work exploits the risk assessment analyses (Figures A2-A6) done in a previous incident research of ours: the logic and assumptions are nevertheless explained in this report, and all important info and schemas are listed in the Appendix A. CERT-UA, ESET, MITRE ATT&CK for ICS, Nozomi Networks and Netresec are the main technical literature sources. NIST CSF 2.0 and NIST incident-response guidance structure the Detect, Respond and Recover side of the model. Where no public frequency exists, the probabilities are structured as calibrated judgment by our group. This means that the NPTs are our transparent, source-anchored modeling judgment, not empirical base rates. For this reason, the numerical output should mainly be read by comparing scenarios under the same assumptions. All probabilities are nevertheless anchored on verified sources and technical literature, and not invented from scratch.

2.2 Modeling strategy

The strategy is deliberately compact. The model contains sixteen nodes, enough to represent the Trigger-Control-Risk Event-Mitigant-Consequence structure (see Appendix A) without attempting to reproduce the full attack kill chain or the full network. Some nodes are deliberate aggregations. Valid_CE condenses several technical mini-steps, including malware staging, IEC-104 session validity, addressing and command semantics. Respond also compresses several operational mini-steps, including incident escalation, command blocking, coordination and containment. This compactness improves interpretability, but it is also treated as a limitation in Section 4. Nonetheless, the model tries to be as realistic as possible.

3 The Bayesian Network model

3.1 Nodes and types

The model contains sixteen nodes (9 root + 7 conditional). These are either boolean (3) or ranked (13). Boolean are used for technical states that are naturally binary in this model, such as whether OT access exists, while ranked nodes are used for ordinal maturity (Low, Medium, High) or severity concepts (None, Partial or Limited, Severe). This Boolean and ranked structure is a simplification, but it is also a modeling choice suited to the data. The price is that some real variables become compressed. Nonetheless, all info about the details of the attack can be found in the references. Appendix B lists the sixteen nodes in full, including states, definitions and node-specific source logic.

Table 1: Mapping from the risk structure (Appendix A, figure A1) to the AgenaRisk nodes.

Risk role	Nodes	Meaning in the model
Trigger / attacker preparation	OT_Access; OT_Knowledge; Malware_Tailoring	Access, target knowledge and malware tailoring make the technical attack feasible.
Intermediate technical event	Valid_CE	Valid Command Execution. A compact technical node covering IEC-104 staging, addressing and command semantics.
Control 1 - Detect	OT_Visibility; Threat_Interpretation; Detect	Monitoring and interpretation before the risk event.
Control 2 - Respond	Response_Timeliness; Response_Coordination; Respond	Operational containment that acts before and after the risk event.
Risk event	OT_Hijacked	Loss of legitimate operational control.
Consequence 1	Power_Disruption	Immediate operational disruption at substation, control or power-system level.
Mitigant - Recover	Manual_Fallback; Restoration_Capability; Recover	Recovery capability after disruption.
Consequence 2	Service_Impact	Final user-facing disruption after Power_Disruption and Recover are combined.

3.2 Structure and links

The directed acyclic graph follows two connected branches. The first is the technical attack branch. OT_Access, OT_Knowledge and Malware_Tailoring feed Valid_CE because an Industroyer2-like operation requires access to an OT or OT-adjacent environment, target knowledge and correctly tailored IEC-104 command logic. OT_Access also influences OT_Hijacked directly, because a foothold remains necessary even when valid command execution is technically possible. See that OT_Hijacked represents the core risk event of our schema. Valid_CE is intentionally a compact node representing the technical steps for malware's Command Execution. The second branch is the NIST CSF defensive chain. OT_Visibility and Threat_Interpretation feed Detect. Detect then feeds Respond together with Response_Timeliness and Response_Coordination. Detect also feeds OT_Hijacked directly. This creates two paths from monitoring to the risk event: a direct path, where detection prevents or interrupts hijacking, and an indirect path, where detection enables an effective response that also reduces hijacking probability. This double influence is a modeling way to emphasize monitoring as the first defensive barrier. Respond has three roles in the graph. First, it is a control on OT_Hijacked. Second, it is a parent of Power_Disruption, because timely and coordinated containment can limit physical disruption after a control attempt. Third, it is a parent of Recover, because the quality of response affects handover to restoration, operational fallback and service recovery. This link means Recover is not independent from the upstream defensive chain. The consequence branch then

separates Power_Disruption from Service_Impact: Power_Disruption is the immediate operational disruption, while Service_Impact is the final consequence experienced by users after recovery conditions are taken into account.

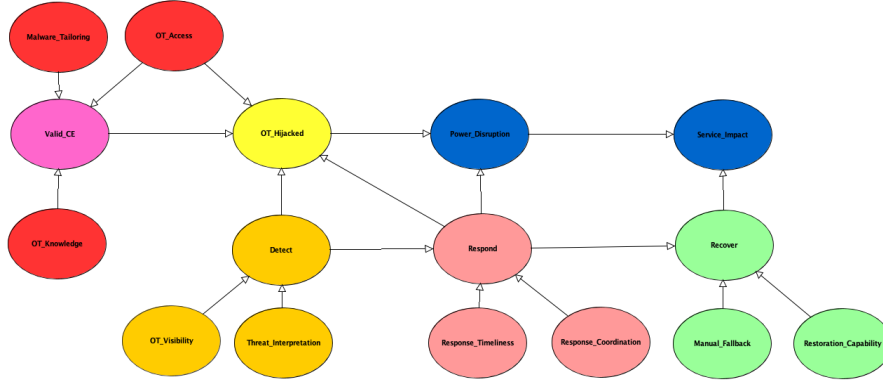


Figure 1: Full AgenaRisk Bayesian network with 16 nodes.

Some nodes are designed with more than one arc/influence. This is deliberately implemented to give more structural importance to the nodes OT_Access and the NIST Detect-Respond-Recover chain. We worked on this version to ensure a realistic representation of the cyberattack and of the complexity of the security of a cyber-physical system. To be as compliant as possible with the assignment, we provide a more linear version of the schema in Appendix A (Figure A8).

3.3 Assumptions and considerations about CPTs

The root priors are treated as case-informed or framework-informed baselines, not as empirical population frequencies. They allow hard evidence to be entered in the scenario analysis. Our main modeling assumption is monotonicity: stronger attacker capability increases attack feasibility, while stronger Detect, Respond and Recover capabilities reduce the probability or severity of downstream consequences. Full priors and CPTs are reported in Appendix C. We built the probabilities following this logic and anchoring on viable sources. For Cases 1 to 3, the most influential table is OT_Hijacked (i.e. the main risk event), because with the same attacker evidence, changes in Detect and Respond strongly shift the probability of hijacking. Power_Disruption then translates the risk event into operational severity, while Service_Impact converts this disruption into the final user-facing consequence after Recover is considered. Respond is especially influential because it affects OT_Hijacked, Power_Disruption and Recover. This is theoretically defensible, since response can influence prevention, containment and recovery hand-over, but it also makes the model partly dependent on the calibration of Respond. The Recover CPT is central in Case 4, where Severe Power_Disruption is fixed and Manual_Fallback and Restoration_Capability are varied to assess their effect on Recover and final Service_Impact.

4 Weaknesses and limits of the model

The first limitation is calibration under sparse evidence. The model is anchored to the Industroyer2 near miss and to qualitative incident analysis, not to a large dataset of independent attacks. Public sources support the structure of the links, but they do not provide robust frequencies for attacker access, detection quality, response speed or recovery effectiveness. Nevertheless, we made the model viable for recalibration for further data input and for other OT-centric attacks. The second limitation is node compression. Some nodes deliberately aggregate several mechanisms: Valid_CE includes malware staging, IEC-104 session validity, addressing and command syntax, while Respond includes escalation, command blocking, coordination and containment. This keeps the network readable, but it also makes these nodes broad and hard to measure. Nonetheless, a more tailored schema may be built using ours. The third limitation is the impact of assumptions. Respond influences OT_Hijacked, Power_Disruption and Recover, so the model is partly driven by this node. A different calibration of the Respond CPT could move several downstream distributions together. A stronger robustness analysis would test alternative CPTs for Respond, OT_Hijacked, Recover and Service_Impact, and check whether the ranking of the scenarios remains stable. The fourth limitation is the static nature of the model. Service_Impact is an ordinal severity class, not a full socio-economic loss model. This creates a measurement limitation, because events with the same severity label may differ in duration, geographic spread, number of users affected or restoration cost. The model also omits

time dynamics and variables important for cyber risk assessment such as segmentation quality, remote access path, authentication strength, operator staffing, backup integrity and adversary actions against recovery.

5 Scenario analysis and quantitative results

The scenarios were run in AgenaRisk by entering hard evidence and reading posterior distributions. This is a posterior-inference exercise under a fixed model calibration. The first three cases use the same attacker evidence: OT_Access=True, OT_Knowledge=High and Malware_Tailoring=High. The comparison therefore isolates how Detect and Respond evidence changes the posterior distribution of OT_Hijacked, Power_Disruption, Recover and Service_Impact. Case 4 has a different methodological purpose: it conditions on Severe Power_Disruption and varies the direct recovery parents to test the final mitigant branch. Full cases' output is reported in Appendix A.

Table 2: Posterior results for Cases 1 to 3 from the supplied AgenaRisk screenshots.

Scenario	Detect High (%)	Respond High (%)	Valid_CE True (%)	OT_Hijacked True (%)	Power Severe (%)	Recover High (%)	Service Severe (%)
Case 1 - Strong Detect and Respond	75.000	69.500	85.000	26.212	11.287	18.125	12.147
Case 2 - Weak Detect and Respond	5.000	2.350	85.000	69.275	46.639	10.943	39.206
Case 3 - Medium Detect and Respond	20.000	15.250	85.000	45.228	24.040	14.625	22.033

5.1 Case 1 - Strong Detect and Respond against skilled attacker (2022 attack)

Case 1 is the high-maturity posterior run. Under the fixed capable-attacker evidence, high OT_Visibility, Threat_Interpretation, Response_Timeliness and Response_Coordination give Detect=High at 75.000% and Respond=High at 69.500%. The model estimates OT_Hijacked=True at 26.212%, Severe Power_Disruption at 11.287% and Severe Service_Impact at 12.147%. See that 2022 attack resulted in no Power Disruption and no Service Impact.

5.2 Case 2 - Weak Detect and Respond against skilled attacker

Case 2 keeps the same attacker evidence but sets the direct Detect and Respond drivers to Low. The posterior probability of OT_Hijacked=True rises to 69.275%, Severe Power_Disruption to 46.639% and Severe Service_Impact to 39.206%. The difference from Case 1 is therefore not produced by a different adversary, but by different evidence on the defensive branch.

5.3 Case 3 - Medium Detect and Respond against skilled attacker (2016 attack)

Case 3 is the intermediate statistical benchmark. With Medium values on the direct Detect and Respond drivers, Severe Service_Impact is 22.033%. This is 9.886 percentage points above Case 1 and 17.173 percentage points below Case 2. The monotonic ordering is important methodologically: under this calibration, stronger defensive evidence consistently shifts probability mass away from severe outcomes. Note that the first Industroyer was deployed on 2016 resulting in partial Service_Impact.

5.4 Case 4 - Recovery comparison after severe disruption

Case 4 has a different purpose from the first three cases. It does not keep the same assumptions as Cases 1 to 3. It enters Power_Disruption=Severe as hard evidence and then changes only the direct recovery trigger parents,

Manual_Fallback and Restoration_Capability. This case is therefore split in two: Recover triggers are set at high in case 4A and at low in 4B. Respond remains connected as a parent of Recover but left untouched. The comparison therefore asks how much the direct recovery capabilities change the final consequence once a severe operational disruption has already occurred.

Table 3: Recovery comparison when Severe Power_Disruption is entered as evidence. PD=Power_Disruption, MF=Manual_Fallback, RC=Restoration_Capability.

Recovery comparison	Evidence	Recover Low (%)	Recover Medium (%)	Recover High (%)	Service None (%)	Service Limited (%)	Service Severe (%)
Case 4A - Strong direct recovery parents	PD=Severe; MF=High; RC=High	16.571	38.385	45.044	3.186	39.761	57.053
Case 4B - Weak direct recovery parents	PD=Severe; MF=Low; RC=Low	81.814	15.436	2.750	1.264	18.060	80.675

With strong direct recovery parents, Recover=High is 45.044% and Severe Service_Impact is 57.053%. With weak direct recovery parents, results are visibly different: Recover=Low is 81.814% and Severe Service_Impact is 80.675%. This is a conditional comparison of the recovery branch, not a claim that recovery is independent from response. The result means that recovery shifts the final severity distribution, but it cannot fully offset a severe operational disruption.

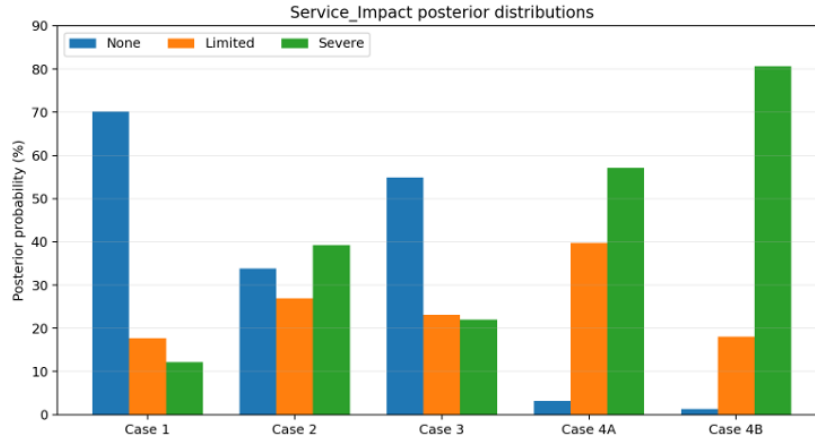


Figure 2: Posterior distribution of Service_Impact across the five AgenaRisk runs.

6 Conclusion

This report builds a compact Bayesian network for an Industroyer2-like attack and uses AgenaRisk to compare posterior distributions under different evidence settings. The purpose is not to predict a real blackout frequency, but to show how attacker capability, Detect, Respond and Recover assumptions shift the probability of final service disruption. The results leads to four main reasonings. First, Detect and Respond strongly affect the risk event: with the same attacker evidence, OT_Hijacked=True rises from 26.212% in the strong defensive case to 69.275% in the weak defensive case. Second, this propagates to final consequences: Severe Service_Impact rises from 12.147% to 39.206%. Third, Detect matters both directly, by reducing OT_Hijacked, and indirectly, by improving Respond. Fourth, Recover remains an important final mitigant: after Severe Power_Disruption is fixed, strong direct recovery parents reduce Severe Service_Impact by 23.622 percentage points compared with weak recovery parents. The main limitation is calibration under sparse evidence: the model is based on one detailed near-miss, public technical sources and structured NPT judgement. Future work should test alternative CPTs, separate over-aggregated nodes such as Valid_CE, include time dynamics, and measure Service_Impact with duration, users affected, geography and cost. Also, more tailored variations of our schema may be used for deeper scenario simulations.

References

- [1] CERT-UA. *Advisory #4435: Sandworm / UAC-0082 cyberattack on Ukrainian energy facilities using Industroyer2 and CaddyWiper*. April 2022.
- [2] ESET Research. *Industroyer2: Industroyer reloaded*. WeLiveSecurity, 12 April 2022.
- [3] Nozomi Networks Labs. *Industroyer2: Analysis of the IEC-104 payload*. April 2022.
- [4] Netresec. *Industroyer2 IEC-104 analysis*. April 2022.
- [5] MITRE ATT&CK for ICS. *Software entry S1072: Industroyer2*. MITRE Corporation.
- [6] National Institute of Standards and Technology (NIST). *Framework for Improving Critical Infrastructure Cybersecurity*. Version 2.0, February 2024.
- [7] European Union Agency for Cybersecurity. *Cybersecurity of Critical Sectors: Guidance on Critical Infrastructure Resilience*. ENISA.
- [8] Previous Group Report. *Reason's Model, FTA, ETA, FMEA and HOF Analysis of the Industroyer2 Cyberattack on the Ukrainian Power Grid*. Politecnico di Milano, Academic Year 2025/2026.

7 Appendix

7.1 Appendix A. Important figures and AgenaRisk screenshots

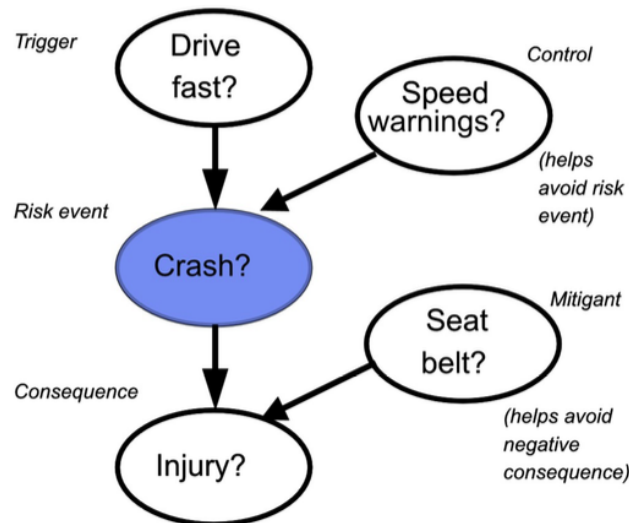


Figure A1. Course reference pattern for Trigger, Control, Risk Event, Mitigant and Consequence.

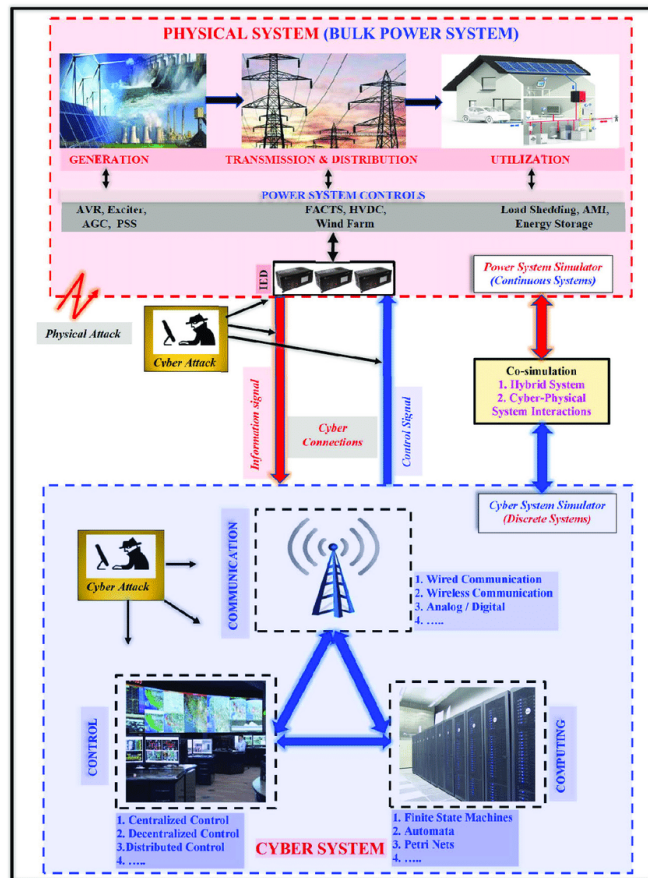


Figure A2. Cyber-physical power-system context.

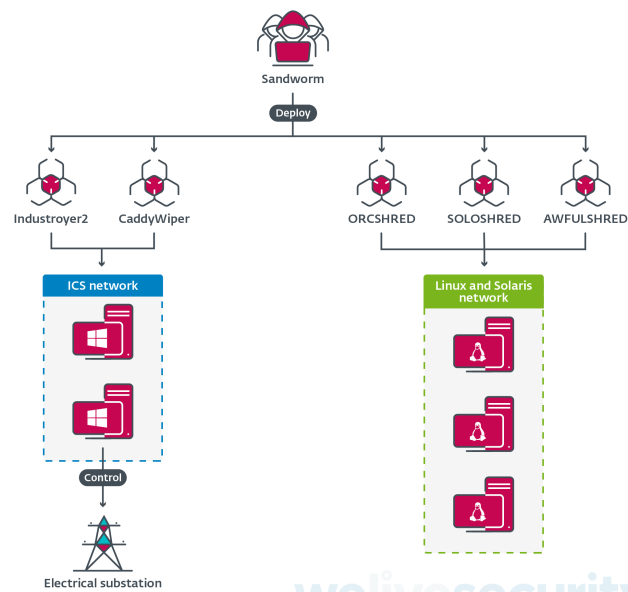


Figure A3. Sandworm and Industroyer2 attack schema.

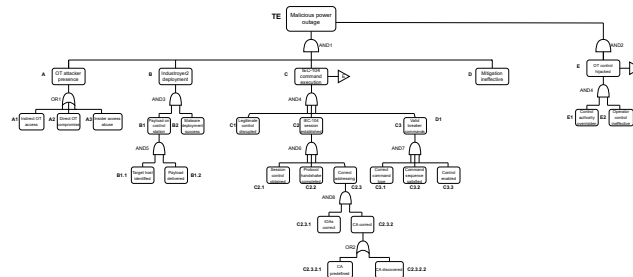


Figure A4. Fault Tree Analysis from our previous incident report.

IE	PE1	PE2	PE3	PE4	PE5	OUTCOME
Success 						No Impact - 0
						No Impact - 0
						No Impact - 0
Failure 						Partial Blackout - 1
						Partial Blackout - 1
						Total Blackout - 2

Figure A5. Event Tree Analysis from our previous incident report.

Event ID	Function	Failure Mode	Effect	Possible Causes	Existing Controls (2022)	Suggested Improvements
PE1	OT/ICS monitoring and incident detection	Late or missed detection of malicious activity	Escalation to command execution phase (PE2)	Alert overload, insufficient OT context, weak IT-OT correlation, human fatigue	SOC monitoring, CERT-UA coordination, threat intelligence support	OT-specific detection rules, improved IT-OT visibility, regular Incident Response drills, SOC-OT team integration
PE4	Operational response and control recovery	Delayed or ineffective recovery of OT control	Prolonged disruption or partial blackout	Unclear authority, insufficient training, lack of rehearsed procedures	Documented procedures, manual override capabilities	Regular operator training, crisis simulations, clear authority chain, improved human-machine interfaces
PE5	IT/OT recovery and resilience	Recovery impeded by IT disruption (e.g. wipers, unavailable backups)	Extended outage duration, wider impact	Tight IT-OT coupling, online-only backups, insufficient segregation	Periodic backups, basic segmentation	Offline/immutable backups, stronger IT-OT segregation, tested recovery plans, dependency mapping

Figure A6. FMEA from our previous incident report.

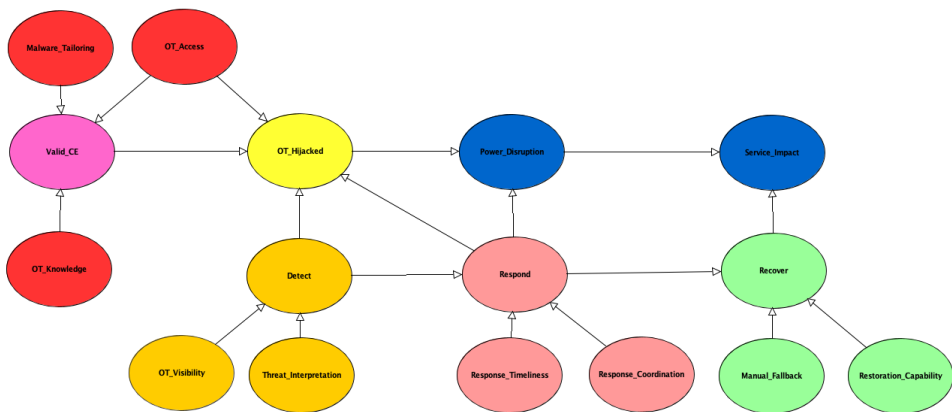


Figure A7. AgenaRisk network structure.

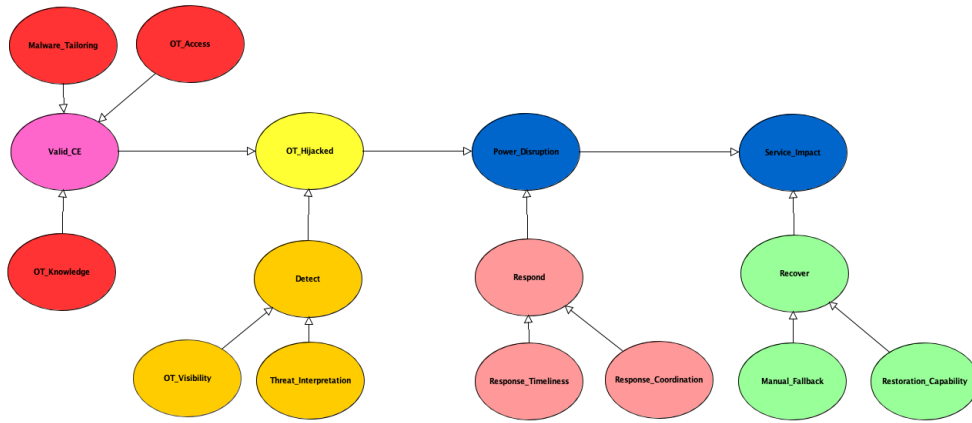


Figure A8. Simpler version of the BN.

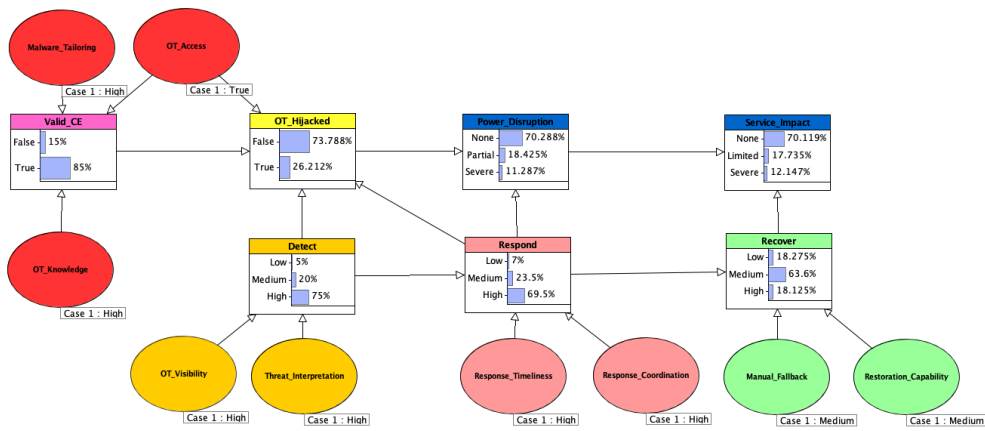


Figure A9. AgenaRisk output for Case 1.

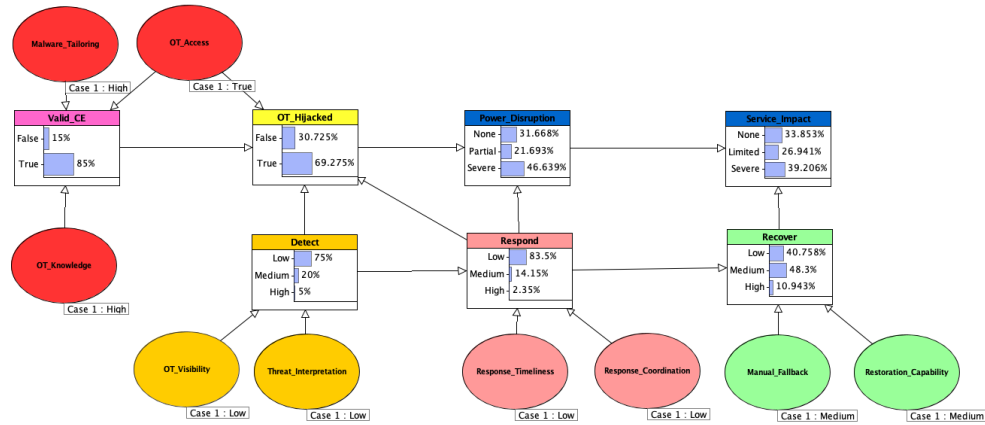


Figure A10. AgenaRisk output for Case 2.

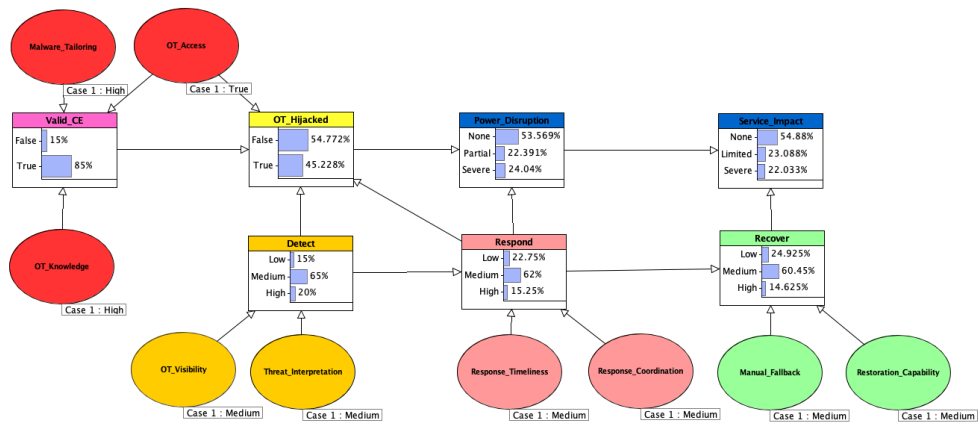


Figure A11. AgenaRisk output for Case 3.

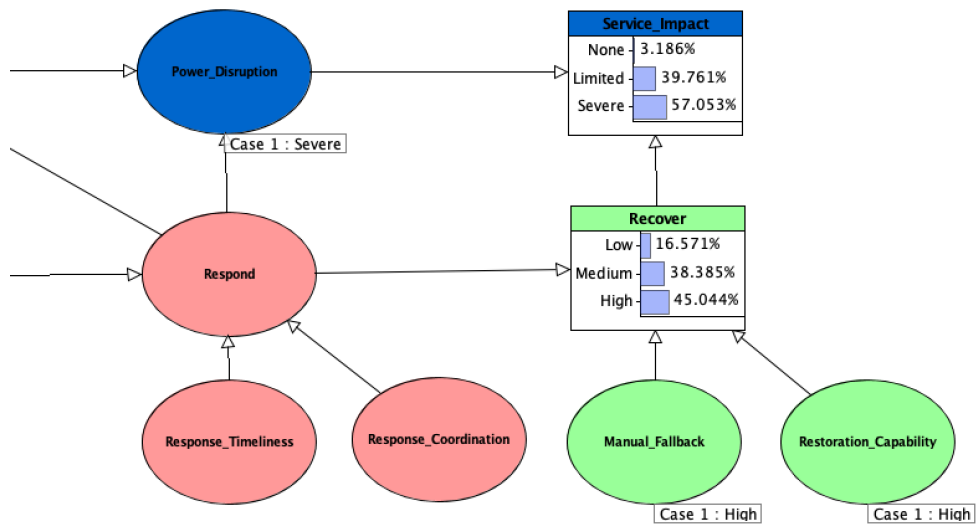


Figure A12. AgenaRisk output for Case 4A.

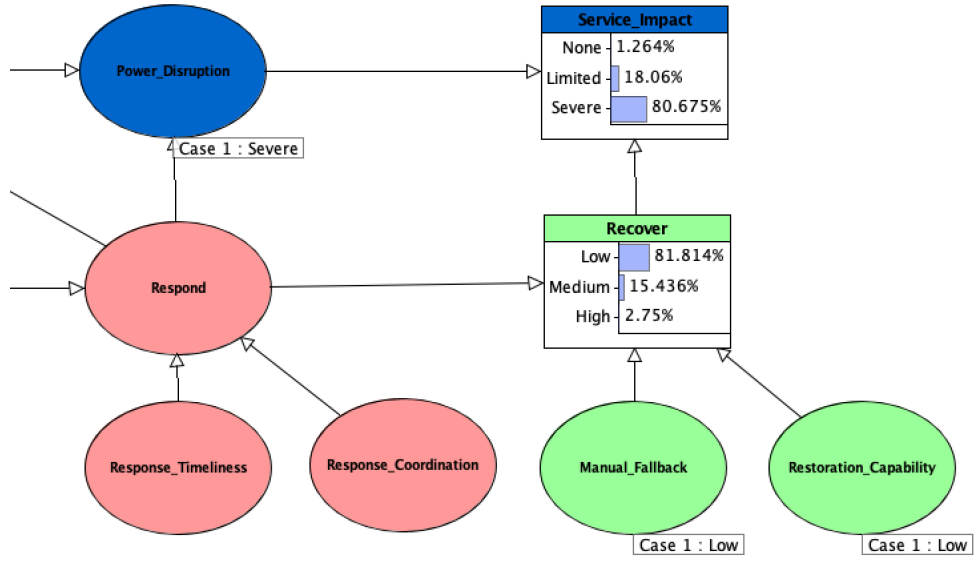


Figure A13. AgenaRisk output for Case 4B.

7.2 Appendix B. Node definitions and source logic

Node	States	Definition / model role	Source logic
Malware_Tailoring	Low / Medium / High	Trigger. Degree of target-specific malware customization.	ESET, MITRE, Nozomi and Netresec on Industroyer2 customization and IEC-104 payload characteristics; attached incident report.
OT_Knowledge	Low / Medium / High	Trigger. Attacker knowledge of the OT architecture, IEC-104 addressing and target parameters.	Nozomi and Netresec IEC-104 analysis; ESET technical write-up; previous FTA branches on Industroyer2 deployment and command execution.
OT_Access	False / True	Trigger. Foothold in OT or OT-adjacent systems. It influences both Valid_CE and OT_Hijacked.	CERT-UA advisory and attached incident report on attacker presence; previous FTA branch A on OT attacker presence.
Valid_CE	False / True	Intermediate technical event. Valid Command Execution through correct staging, IEC-104 session validity, addressing and command semantics. This is a deliberate compression of several mini-steps.	Nozomi and Netresec IEC-104 payload analysis; ESET Industroyer2 analysis; previous FTA branch C on IEC-104 command execution.
OT_Visibility	Low / Medium / High	Detect driver. Visibility of relevant OT activity and protocol-level anomalies.	NIST CSF Detect; previous FMEA PE1; attached incident report on early visibility of the operation.
Threat_Interpretation	Low / Medium / High	Detect driver. Correct interpretation of anomalous activity as malicious and operationally relevant.	NIST CSF Detect; attached incident report and ESET/CERT-UA narrative on interpreting the staging activity before execution.
Detect	Low / Medium / High	NIST CSF Detect control, conditional on visibility and interpretation. It affects OT_Hijacked directly and indirectly through Respond.	NIST CSF Detect; previous ETA PE1; course bowtie/control logic; attached incident report near-miss logic.
Response_Timeliness	Low / Medium / High	Respond driver. Speed of reaction after detection and before or during command execution.	NIST Respond; CERT-UA/ESET timeline in the attached report; previous ETA response events.

Response_Coordination	Low / Medium / High	Respond driver. Coordination across SOC, OT operators, CERT, vendors and external responders.	NIST Respond; attached report on coordination among CERT-UA, operator, ESET and Microsoft; previous FMEA response rows.
Respond	Low / Medium / High	NIST CSF Respond control. A compressed node covering escalation, containment, command blocking and operational coordination. It influences OT_Hijacked, Power_Disruption and Recover.	NIST CSF Respond; previous ETA PE2-PE4 and FMEA operational-response rows; attached incident report on containment before blackout.
OT_Hijacked	False / True	Risk event. Attacker overrides or obtains unauthorised operational control of OT devices.	Previous FTA top event and branch E; ESET, Nozomi and Netresec analysis of the IEC-104 control-command capability.
Power_Disruption	None / Partial / Severe	Immediate operational consequence at substation, control-room or power-system level. It is not the same as final user service impact.	Previous ETA blackout outcomes; IEC-104 command context from ESET, Nozomi and Netresec; course risk-event/consequence structure.
Manual_Fallback	Low / Medium / High	Recover driver. Availability and usability of manual or non-digital operational fallback.	NIST Recover; ENISA critical-infrastructure resilience guidance; previous FMEA recovery/fallback discussion.
Restoration_Capability	Low / Medium / High	Recover driver. Capacity to restore systems, data and service after disruption and wiper activity.	NIST Recover; ENISA resilience guidance; CERT-UA/ESET reporting on CaddyWiper and ORCSHRED/SOLOSHRED/AWFULSHRED wipers.
Recover	Low / Medium / High	NIST CSF Recover mitigant, conditional on Respond, Manual_Fallback and Restoration_Capability.	NIST Recover; previous ETA PE4-PES; previous FMEA recovery/resilience rows; attached report on wipers degrading restoration.
Service_Impact	None / Limited / Severe	Final consequence. End-user-facing electricity service disruption after Power_Disruption and Recover are combined.	Course consequence model; previous ETA final outcomes; NIST/ENISA resilience logic for critical-service continuity.

Table B1. Node definitions and source logic.

7.3 Appendix C. Priors and conditional probability tables

All probability tables are the modelling calibration used in AgenaRisk. The tables are source-anchored but should be read as our group structured judgement, since direct empirical frequencies are not viable. Sensitivity analyses are recommended to test these probability distributions.

Table C1. Root-node prior distributions.

Root node	State probabilities	Calibration
OT_Access	False 0.75; True 0.25	Case-informed; assumed by default.
OT_Knowledge	Low 0.30; Medium 0.45; High 0.25	Literature-informed; the strongest
Malware_Tailoring	Low 0.20; Medium 0.40; High 0.40	Case-based calibration; medium and
OT_Visibility	Low 0.25; Medium 0.50; High 0.25	Framework-informed
Threat_Interpretation	Low 0.20; Medium 0.50; High 0.30	Framework-informed
Response_Timeliness	Low 0.20; Medium 0.50; High 0.30	Literature- and
Response_Coordination	Low 0.20; Medium 0.50; High 0.30	Literature- and
Manual_Fallback	Low 0.25; Medium 0.50; High 0.25	Framework-informed
Restoration_Capability	Low 0.25; Medium 0.50; High 0.25	Framework-informed; default.

Table C2. Detect CPT.

OT_Visibility	Threat_Interpretation	Detect Low	Detect Medium
High	High	0.05	0.20
Medium	Medium	0.15	0.65
Low	Low	0.75	0.20
High	Medium	0.10	0.45
Medium	High	0.10	0.45
Low	Medium	0.45	0.45
Medium	Low	0.45	0.45
High	Low	0.30	0.40
Low	High	0.30	0.40

Table C3. Valid_CE CPT. $P(\text{False})=1-P(\text{True})$.

OT_Access	OT_Knowledge	Malware_Tailoring
False	Any	Any
True	Low	Low
True	Low	Medium
True	Low	High
True	Medium	Low
True	Medium	Medium
True	Medium	High
True	High	Low
True	High	Medium
True	High	High

Table C4. Respond CPT.

Detect level	Response_Timeliness / Response_Coordination	Respond Low	Respond Medium
Detect=High	High/High	0.05	0.20
Detect=High	Medium/Medium	0.15	0.65
Detect=High	Low/Low	0.75	0.20
Detect=High	High/Medium or Medium/High	0.10	0.45
Detect=High	Low/Medium or Medium/Low	0.45	0.45
Detect=High	High/Low or Low/High	0.30	0.40
Detect=Medium	High/High	0.10	0.30
Detect=Medium	Medium/Medium	0.20	0.65
Detect=Medium	Low/Low	0.80	0.17
Detect=Medium	High/Medium or Medium/High	0.15	0.55
Detect=Medium	Low/Medium or Medium/Low	0.50	0.42
Detect=Medium	High/Low or Low/High	0.35	0.45
Detect=Low	High/High	0.25	0.50
Detect=Low	Medium/Medium	0.45	0.45
Detect=Low	Low/Low	0.85	0.13
Detect=Low	High/Medium or Medium/High	0.35	0.50
Detect=Low	Low/Medium or Medium/Low	0.60	0.35

Table C5. OT_Hijacked CPT. $P(\text{False})=1-P(\text{True})$.

OT_Access	Valid_CE	Detect	Respond	P(OT_Hijacked=True)
OT_Access=False	Any	Any	Any	0.01
OT_Access=True	Valid_CE=False	High	High	0.05
OT_Access=True	Valid_CE=False	High	Medium	0.08
OT_Access=True	Valid_CE=False	High	Low	0.12
OT_Access=True	Valid_CE=False	Medium	High	0.10
OT_Access=True	Valid_CE=False	Medium	Medium	0.15
OT_Access=True	Valid_CE=False	Medium	Low	0.22
OT_Access=True	Valid_CE=False	Low	High	0.18
OT_Access=True	Valid_CE=False	Low	Medium	0.25
OT_Access=True	Valid_CE=False	Low	Low	0.35
OT_Access=True	Valid_CE=True	High	High	0.20
OT_Access=True	Valid_CE=True	High	Medium	0.30
OT_Access=True	Valid_CE=True	High	Low	0.42
OT_Access=True	Valid_CE=True	Medium	High	0.35
OT_Access=True	Valid_CE=True	Medium	Medium	0.50
OT_Access=True	Valid_CE=True	Medium	Low	0.65
OT_Access=True	Valid_CE=True	Low	High	0.55
OT_Access=True	Valid_CE=True	Low	Medium	0.72
OT_Access=True	Valid_CE=True	Low	Low	0.85

Table C6. Power_Disruption CPT.

OT_Hijacked	Respond	Power None	Power Partial	Power Severe
False	Any	0.90	0.08	0.02
True	High	0.20	0.55	0.25
True	Medium	0.10	0.45	0.45
True	Low	0.05	0.25	0.70

Methods for Data Analytics and Risk Assessment

Respond level	Manual_Fallback / Restoration_Capability	Recover Low	Recover Medium	Recover High
Respond=High	High/High	0.05	0.20	0.75
Respond=High	Medium/Medium	0.15	0.65	0.20
Respond=High	Low/Low	0.75	0.20	0.05
Respond=High	High/Medium or Medium/High	0.10	0.45	0.45
Respond=High	Low/Medium or Medium/Low	0.45	0.45	0.10
Respond=High	High/Low or Low/High	0.30	0.40	0.30
Respond=Medium	High/High	0.10	0.30	0.60
Respond=Medium	Medium/Medium	0.20	0.65	0.15
Respond=Medium	Low/Low	0.80	0.17	0.03
Respond=Medium	High/Medium or Medium/High	0.15	0.55	0.30
Respond=Medium	Low/Medium or Medium/Low	0.50	0.42	0.08
Respond=Medium	High/Low or Low/High	0.35	0.45	0.20
Respond=Low	High/High	0.25	0.50	0.25
Respond=Low	Medium/Medium	0.45	0.45	0.10
Respond=Low	Low/Low	0.85	0.13	0.02
Respond=Low	High/Medium or Medium/High	0.35	0.50	0.15
Respond=Low	Low/Medium or Medium/Low	0.60	0.35	0.05
Respond=Low	High/Low or Low/High	0.50	0.40	0.10

Table C8. Service_Impact CPT.

Power_Disruption	Recover	Service None	Service Limited	Service Severe
None	Any	0.95	0.04	0.01
Partial	High	0.35	0.55	0.10
Partial	Medium	0.15	0.65	0.20
Partial	Low	0.05	0.55	0.40
Severe	High	0.05	0.55	0.40
Severe	Medium	0.02	0.33	0.65
Severe	Low	0.01	0.14	0.85

7.4 Appendix D. Scenario evidence and full output tables

Table D1. Scenario evidence.

Scenario	Evidence entered in AgenaRisk
Case 1	OT_Access=True; OT_Knowledge=High; Malware_Tailoring=High; OT_Visibility=High; Threat_Interpretation=High; Response_Timeliness=High; Response_Coordination=High; Manual_Fallback=Medium; Restoration_Capability=Medium.
Case 2	OT_Access=True; OT_Knowledge=High; Malware_Tailoring=High; OT_Visibility=Low; Threat_Interpretation=Low; Response_Timeliness=Low; Response_Coordination=Low; Manual_Fallback=Medium; Restoration_Capability=Medium.
Case 3	OT_Access=True; OT_Knowledge=High; Malware_Tailoring=High; OT_Visibility=Medium; Threat_Interpretation=Medium; Response_Timeliness=Medium; Response_Coordination=Medium; Manual_Fallback=Medium; Restoration_Capability=Medium.
Case 4A	Power_Disruption=Severe; Manual_Fallback=High; Restoration_Capability=High. Respond is not fixed and remains connected to Recover.
Case 4B	Power_Disruption=Severe; Manual_Fallback=Low; Restoration_Capability=Low. Respond is not fixed and remains connected to Recover.

Table D2. Full output distributions for Cases 1 to 3.

Output node	Case 1	Case 2	Case 3
Detect distribution	Low 5.000%; Medium 20.000%; High 75.000%	Low 75.000%; Medium 20.000%; High 5.000%	Low 15.000%; Medium 65.000%; High 20.000%
Respond distribution	Low 7.000%; Medium 23.500%; High 69.500%	Low 83.500%; Medium 14.150%; High 2.350%	Low 22.750%; Medium 62.000%; High 15.250%
Valid_CE	False 15.000%; True 85.000%	False 15.000%; True 85.000%	False 15.000%; True 85.000%
OT_Hijacked	False 73.788%; True 26.212%	False 30.725%; True 69.275%	False 54.772%; True 45.228%
Power_Disruption	None 70.288%; Partial 18.425%; Severe 11.287%	None 31.668%; Partial 21.693%; Severe 46.639%	None 53.569%; Partial 22.391%; Severe 24.040%
Recover distribution	Low 18.275%; Medium 63.600%; High 18.125%	Low 40.758%; Medium 48.300%; High 10.943%	Low 24.925%; Medium 60.450%; High 14.625%
Service_Impact	None 70.119%; Limited 17.735%; Severe 12.147%	None 33.853%; Limited 26.941%; Severe 39.206%	None 54.880%; Limited 23.088%; Severe 22.033%

Table D3. Full output distributions for Case 4 recovery comparison.

Output node	Case 4A - Strong direct recovery parents	Case 4B - Weak direct recovery parents
Recover distribution	Low 16.571%; Medium 38.385%; High 45.044%	Low 81.814%; Medium 15.436%; High 2.750%
Service_Impact	None 3.186%; Limited 39.761%; Severe 57.053%	None 1.264%; Limited 18.060%; Severe 80.675%
Difference in Service_Impact=Severe	Reference for comparison	+23.622 percentage points versus Case 4A